

HIPAA Findings Remediated — 2026-04-10

All findings from a HIPAA Security Rule review conducted on 2026-04-10. Each finding was verified as resolved by a follow-up re-audit.

PHI Logging (7 findings + 1 pre-existing)

ID	Description	Commit	Files Changed
H3	Claude response content (200 chars) logged to CloudWatch	d92fcb7	app/src/app/api/chat/route.ts
H4	User name, ZIP, provider name logged on every chat request	d92fcb7	app/src/app/api/chat/route.ts
H5	Extraction functions logged requirement/verification content (5 locations)	d92fcb7	app/src/lib/claude.ts
M2	FHIR Patient ID logged in callback console.log	d92fcb7	app/src/app/api/fhir/callback/route.ts
M3	Token refresh error response body logged (could contain tokens)	d92fcb7	app/src/lib/fhir/tokens.ts
M5	Debug redirect URI logged in production OAuth flow	d92fcb7	app/src/app/api/fhir/authorize/route.ts
M7	NPI search logged full input JSON (provider names + location)	d92fcb7	app/src/lib/tools/index.ts
Pre-existing	SkillTriggers object logged with unreportedProcedure (procedure description from claims)	6e93917	app/src/app/api/chat/route.ts

Principle applied: Log the action, never the content. All log lines now emit boolean flags, counts, or lengths instead of PHI values.

Audit Logging (2 findings)

ID	Description	Commit	Files Changed
H1	LOGOUT action never audit-logged (session termination not recorded)	d92fcb7	app/src/app/api/auth/signout/route.ts, app/src/lib/audit.ts
M1	FHIR_DATA_ACCESS and FHIR_DISCONNECT audit entries missing IP and User-Agent	d92fcb7	app/src/app/api/fhir/data/route.ts, app/src/app/api/fhir/disconnect/route.ts

Data Lifecycle (1 finding)

ID	Description	Commit	Files Changed
H2	health_reports (Claude-generated PHI summaries) not purged on Blue Button disconnect	d92fcb7	app/src/app/api/fhir/disconnect/route.ts

audit_logs Hardening (3 findings)

ID	Description	Commit	Files Changed
C1	No CREATE TABLE for audit_logs in any tracked migration file	3307903	scripts/migrate-audit-logs-baseline.sql
H1	No REVOKE UPDATE/DELETE on audit_logs for app DB user	3307903	scripts/migrate-audit-logs-baseline.sql
H2	TypeScript Update type for audit_logs signals UPDATE is valid	3307903	app/src/types/database.ts

FHIR Audit Semantics (1 finding)

ID	Description	Commit	Files Changed
M4	FHIR_DATA_ACCESS fired on paths where no data was returned (no connection, sync failure) and used a 2-hour dedup window that could mask distinct access sessions. Revised to fire only on successful data retrieval, with 5-minute dedup. Sync failures now log as FHIR_DATA_ACCESS_FAILED.	abb3482	app/src/lib/audit.ts, app/src/app/api/fhir/data/route.ts

Verification

All fixes were verified by re-reading the affected code against the original finding descriptions. The full test suite (575 unit tests, 27 E2E auth tests) passed after each commit.